

Audit SSI

Chapitre 4 : Normes, référentiels et bonnes pratiques d'audit SSI

Présentation des normes ISO/IEC essentielles

ISO/IEC 27001 : *Norme de référence pour le SMSI*

- Cadre méthodologique pour établir, mettre en œuvre, maintenir et améliorer un **Système de Management de la Sécurité de l'Information**.
- Permet l'obtention d'une **certification ISO**.
- Contient des **exigences organisationnelles** (politique, responsabilités, audit, actions correctives...).



ISO/IEC 27002 : *Mesures de sécurité*

- Complément de la 27001 : elle **décrit les bonnes pratiques de sécurité à mettre en œuvre**.
- Contient plus de **90 mesures classées en 4 thèmes** : organisationnelles, humaines, physiques et technologiques.
- Utilisée comme base pour **auditer les contrôles techniques** et les pratiques de sécurité.



Présentation des normes ISO/IEC essentielles

ISO/IEC 27005 : *Gestion des risques*

- Norme dédiée à l'analyse et au traitement des **risques liés à la sécurité de l'information**.
- Appuie les processus d'identification des actifs, menaces, vulnérabilités, impacts.
- Sert de base pour **cartographier les risques SSI et justifier les mesures de sécurité**.



ISO/IEC 27007 : *Ligne directrice pour l'audit SSI*

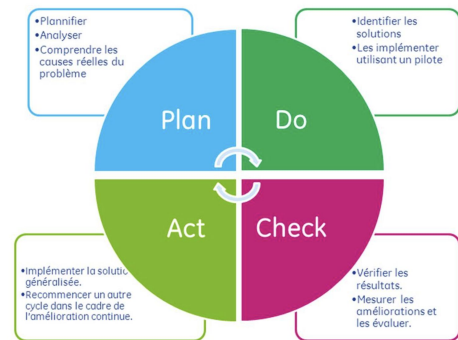
- Norme spécifique à la **conduite des audits des SMSI**.
- Décrit les étapes clés d'un audit, les compétences attendues de l'auditeur, et les **bonnes pratiques pour rédiger les constats et rapports**.



Cycle PDCA : Piloter et auditer la sécurité dans une logique d'amélioration continue

Le modèle **PDCA (Plan-Do-Check-Act)** est un fil conducteur dans les normes ISO :

- **Plan** : Identifier les risques, définir les politiques et les contrôles.
- **Do** : Implémenter les mesures définies.
- **Check** : Contrôler, auditer, mesurer les résultats.
- **Act** : Corriger, améliorer, adapter les processus.

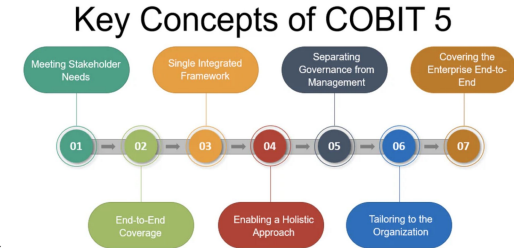


L'audit s'inscrit dans la **phase "Check"**, mais ses constats doivent alimenter les phases suivantes, dans une logique **d'amélioration continue de la sécurité**.

Référentiels et bonnes pratiques complémentaires

COBIT (Control Objectives for Information and Related Technologies)

- Cadre de gouvernance SI reconnu à l'international.
- Permet d'auditer les processus IT en lien avec les **objectifs de contrôle** (planification, acquisition, livraison, surveillance).
- Version COBIT 2019 introduit des **facteurs de conception** et une gouvernance orientée valeur.



ITIL (Information Technology Infrastructure Library)

- Référentiel de gestion des services IT (ITSM).
- Audit possible sur des processus critiques : **gestion des incidents, des changements, des configurations, des niveaux de service**, etc.
- Complète les audits techniques en orientant l'analyse vers **la qualité de service et les responsabilités opérationnelles**.



Référentiels et bonnes pratiques complémentaires

NIST SP800-53 / NIST CSF

- Recommandations du NIST (États-Unis) sur la gestion des risques cybersécurité.
- Organisé en familles de contrôles (accès, audit, communications, continuité, etc.).
- Utilisé comme **cadre d'analyse complémentaire** notamment pour les audits dans les secteurs réglementés (finance, santé...) valeur.



Pourquoi ce chapitre est indispensable à toute mission d'audit SSI

Il donne **le langage commun et les repères méthodologiques** de toute mission d'audit.

Il permet d'**objectiver les constats d'audit** grâce à des critères reconnus internationalement.

Il est indispensable pour **structurer les grilles d'audit**, formaliser les constats et **formuler des recommandations alignées avec les standards**.

Il renforce la **crédibilité** des auditeurs face aux parties prenantes (Direction Générale, DSI, RSSI, régulateurs...).

Enfin, il **prépare à la certification** (ISO 27001, audits externes) et au pilotage d'un SMSI.

Pourquoi ce chapitre est indispensable à toute mission d'audit SSI

Il donne **le langage commun et les repères méthodologiques** de toute mission d'audit.

Il permet d'**objectiver les constats d'audit** grâce à des critères reconnus internationalement.

Il est indispensable pour **structurer les grilles d'audit**, formaliser les constats et **formuler des recommandations alignées avec les standards**.

Il renforce la **crédibilité** des auditeurs face aux parties prenantes (Direction Générale, DSI, RSSI, régulateurs...).

Enfin, il **prépare à la certification** (ISO 27001, audits externes) et au pilotage d'un SMSI.